

2.5 Prioritizing monitoring activities according to resources and security requirements



Friday, September 25, 2026 · 6–10 pm · Online · Then: Lab 1 (5 %) — Integrative Project, Part 1

Cybersecurity: Prevention and Intervention — LEA.D8 (AEC), Dawson College · Cyber.SoHo Educational Hub · Asen Grozdanov

Tonight's plan — one hour, then Lab 1

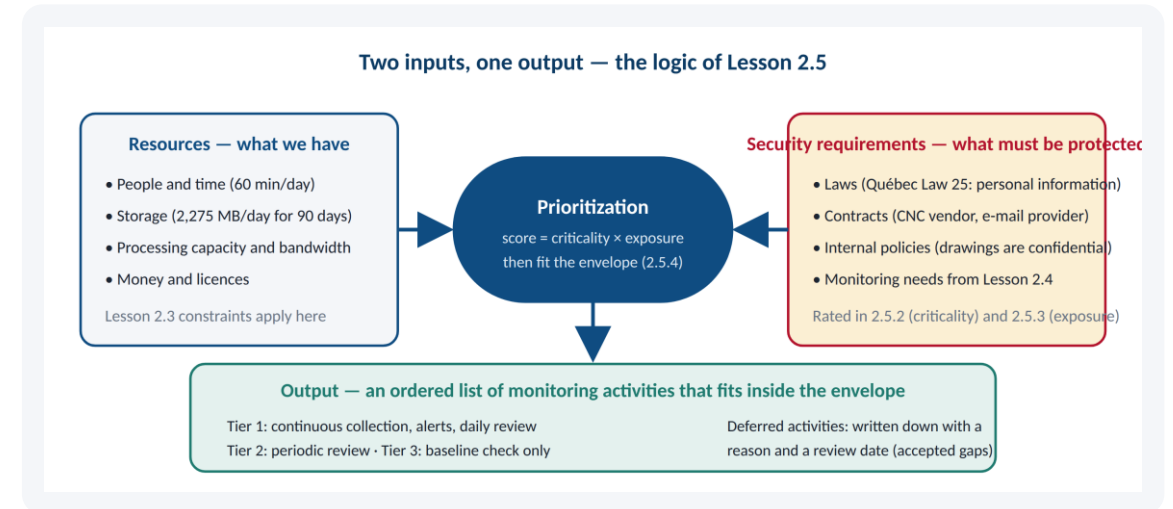
Minutes	Part	What happens
0:00–0:05	Before we begin	Recap of Topic 2, outcomes, running example
0:05–0:18	Lesson 2.5.1	Why prioritize: two inputs, one order; the resource envelope; simulator 1
0:18–0:31	Lesson 2.5.2	Criticality: rating what an asset is worth; simulator 2
0:31–0:44	Lesson 2.5.3	Exposure: rating how likely trouble is; simulator 3
0:44–0:55	Lesson 2.5.4	Priority score, tiers, fitting the envelope, the monitoring plan; simulator 4
0:55–1:00	Lab 1	What Lab 1 asks for tonight, submission rules, legal reminders

Quiz 2 (5 %) is tomorrow and covers all material to date; flash cards and the quiz on the lecture page are for self-study.



Where we are in Topic 2

- Topic 2 = understand the network well enough to decide **what must be watched**
- Lesson 2.1 named the **components**; 2.2 taught **documentation and topology**
- Lesson 2.3 listed the **constraints**; 2.4 the **monitoring needs**
- Tonight, 2.5 turns needs and constraints into **one ordered list of activities**
- Competency EZ01, element 2, criterion 2.3: prioritization in accordance with network resources and security requirements
- Two inputs are named there — **resources** and **security requirements** — and the whole hour is organized around them



Learning outcomes — what you will be able to do

1

Explain, with numbers, why a small organization cannot monitor everything and must choose

2

Rate the **criticality** of an asset from the impact of losing its confidentiality, integrity or availability

3

Rate the **exposure** of an asset from five facts that can be observed without touching the network

4

Compute a **priority score**, assign a **monitoring tier**, and fit the activities into a **resource envelope**

5

Record the result — including what is deferred and why — in the **monitoring plan** for Lab 1



The running example — Ébénisterie Val-des-Pins Inc.

Identifier	Abbreviation	Role at Val-des-Pins
FW-01	FW (Firewall)	Firewall and router; the only path between the office network and the Internet
SW-01, SW-02	SW (Switch)	Core switch in the server room; switch on the shop floor
AP-01	AP (Access Point)	Staff Wi-Fi access point; the guest Wi-Fi is excluded (owner's decision, Class 6)
SRV-FILE-01	SRV (Server)	File server: customer drawings, quotes, shared folders
NAS-01	NAS (Network Attached Storage)	Backup storage unit; receives the nightly backup of SRV-FILE-01
PC-ACCT-01	PC (Personal Computer), ACCT (Accounting)	Accounting and payroll workstation; personal information of employees
CNC-PC-01	CNC (Computer Numerical Control)	Drives the CNC cutting machine; the vendor contract forbids installing any software on it
PC-OFFICE-01 ... 05	PC (Personal Computer)	Five office workstations, rated as a group
PC-SHOP-01	PC (Personal Computer)	Shared computer on the shop floor (time sheets, viewing drawings)
PRN-01	PRN (Printer)	Network printer
MAIL-CLOUD	—	Hosted e-mail service of an external provider; only the provider's audit logs are available
GUEST-WIFI	—	Guest network — excluded from monitoring by the owner (recorded, not rated)

Fictional cabinet-making workshop in Laval, 22 employees — the same organization as Class 6, reused in Labs 1, 2 and 3 (Table 0 on the lecture page: `class7_table0_naming_key.csv`).



2.5.1

Why prioritize: two inputs, one order

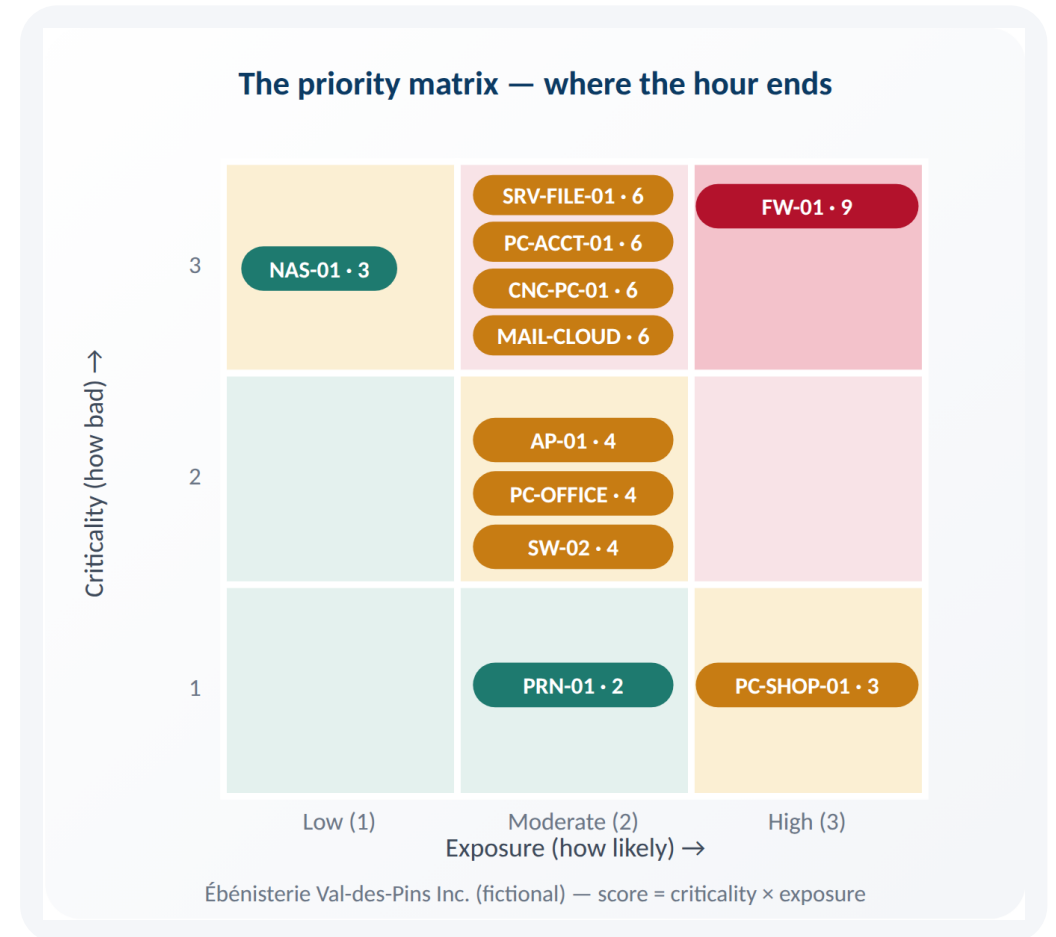


Reading window 0:05–0:18

Concepts: prioritization · monitoring activity · resources · security requirements · resource envelope · retention

Prioritization and monitoring activity

- **Prioritization:** putting activities in order of importance, so the most important are done **first** and get the **largest share** of the resources
- A **monitoring activity** is a defined, repeatable observation of one part of the network
 - "Collect the connection log of FW-01 every day and review it every morning"
 - "Capture the traffic of the switch port that serves CNC-PC-01"
- Each activity names a **source of data**, a way to **collect** it, and a way to **review** it
- Why an order at all? Because **no monitoring activity is free** — every one consumes resources, and a small organization has very few



Input 1 — the resources monitoring consumes (1/2)

People and time

Someone must read what was collected. An alert that nobody reviews protects nothing. At Val-des-Pins: one technician, five hours per week for security.

Storage

Logs and captures are files. A firewall writes hundreds of MB (megabytes) per day; a full capture of an office network writes GB (gigabytes) per day. The retention period multiplies the need: 90 days = 90 days of files on disk at once.



Input 1 — the resources monitoring consumes (2/2)

Processing capacity and bandwidth

A monitoring agent uses CPU (Central Processing Unit) time and RAM (Random Access Memory) on the machine it watches; sending logs uses bandwidth; a mirrored port drops packets when the copied traffic exceeds its capacity. No agent at all on CNC-PC-01 (vendor contract, Lesson 2.3).

Money and licences

Commercial tools are priced per monitored device or per GB of data ingested per day. A free tool still costs the hours needed to learn and maintain it.



Input 2 — where security requirements come from

1

Laws — in Québec, Law 25 obliges an enterprise to protect the personal information it holds (the payroll data on PC-ACCT-01)

2

Contracts — the vendor agreement for the CNC machine; the terms of the cloud e-mail provider

3

Internal policies — the owner's decisions: customer drawings are confidential; the guest Wi-Fi is out of scope

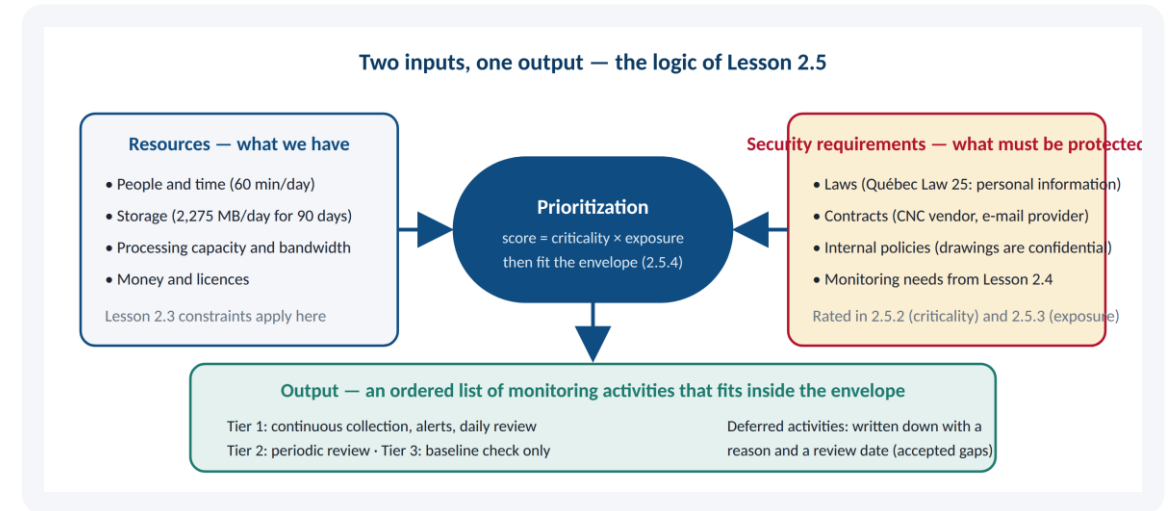
4

Monitoring needs identified in Lesson 2.4 — what must be detected, on which assets, and how quickly



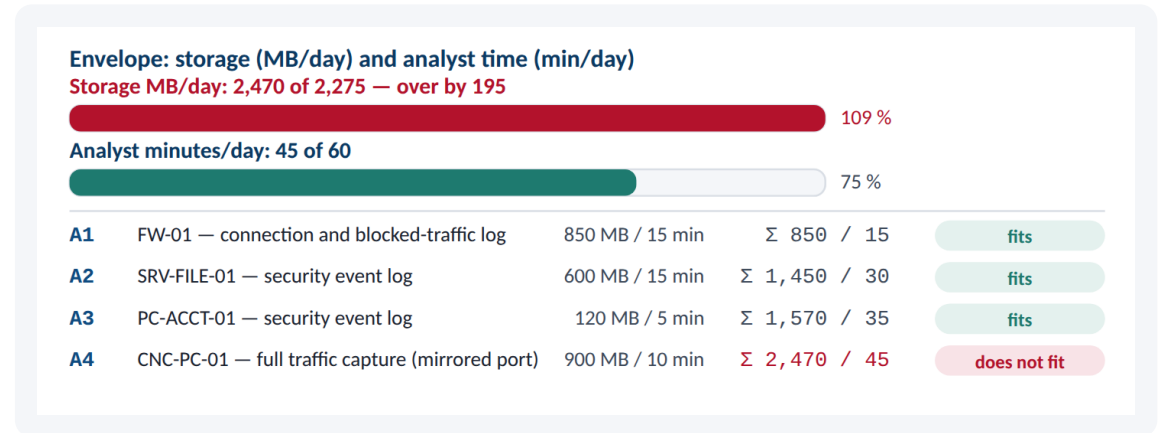
Two inputs, one conflict — and three questions in a fixed order

- Requirements describe what the organization **would like** to watch; resources describe what it **can afford** to watch
- Prioritization resolves the conflict in a **defensible, written** way, by answering three questions in order:
 - **Which assets matter most?** — the criticality question (2.5.2)
 - **Which assets are most likely to be attacked or to fail?** — the exposure question (2.5.3)
 - **Within the budget, what is done first, reduced, or deferred?** — the fitting question (2.5.4)



Two ideas that frame the lesson, and one precise term

- Prioritization is **risk-based**: an asset's place depends on the **harm** its loss would cause and on the **likelihood** of that loss — the two ingredients of a risk assessment (NIST SP 800-30)
- Prioritization is **explicit**: a decision that is not written down cannot be reviewed, defended or improved
- The **resource envelope** = the total amount of each resource dedicated to monitoring, in measurable units:
 - MB (megabytes) per day of storage; minutes per day of analyst time; number of licences
 - Agreed with the owner and written in the plan — not the technician's private estimate
- CCCS (Canadian Centre for Cyber Security) baseline controls for small organizations reason the same way: most of the benefit from a fraction of the effort



Common beginner error — "collect everything now, sort it out later"

- Collected data that **nobody reviews** is worse than useless:
 - It **costs storage**
 - It creates a **legal duty** — logs and captures contain personal information and must be protected (Legal Notice, sections 6.7 and 7.2)
 - It **hides** the few important events among millions of unimportant ones — the "quality of results" problem of Topic 6

[Open: Cyber.SoHo Legal Notice v2.0 — sections 6.7 and 7.2](#)

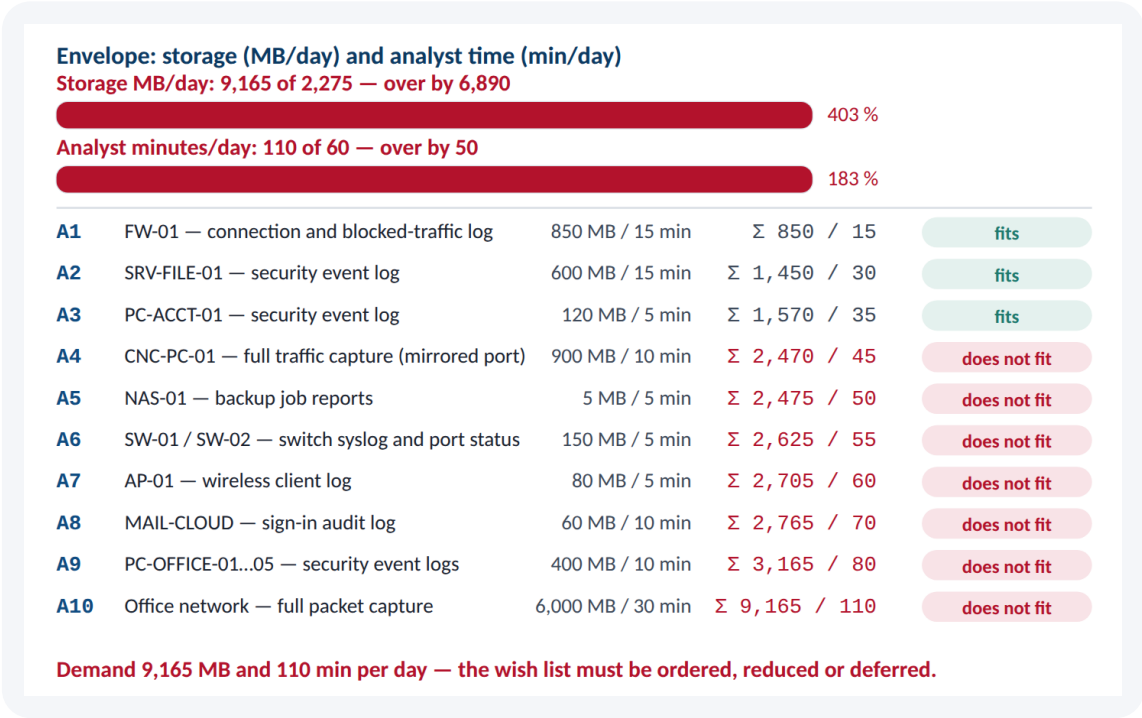


Example 2.5.1 — the wish list does not fit

ID	Candidate activity	Source and method	MB/day	min/day
A1	FW-01 connection and blocked-traffic log	Syslog from the firewall	850	15
A2	SRV-FILE-01 security event log	Windows event log, agent	600	15
A3	PC-ACCT-01 security event log	Windows event log, agent	120	5
A4	CNC-PC-01 network traffic (no agent permitted)	Full capture, mirrored port of SW-02	900	10
A5	NAS-01 backup job reports	Daily report of the backup software	5	5
A6	SW-01 and SW-02 syslog and port status	Syslog from both switches	150	5
A7	AP-01 wireless client log	Syslog from the access point	80	5
A8	MAIL-CLOUD sign-in audit log	Daily export from the provider	60	10
A9	PC-OFFICE-01 to 05 security event logs	Windows event logs, agents	400	10
A10	Full packet capture of the office network	Mirrored port on SW-01	6,000	30
Total of the wish list			9,165	110
	Resource envelope (approved)	200 GB ÷ 90 days; 5 h/week ÷ 5 days	2,275	60

Simulator 1 — the monitoring budget of Val-des-Pins

- **What it does:** converts the approval into a daily envelope, then adds the ten activities one by one, redrawing two budget bars and stopping the moment either resource is exceeded
- $200\text{ GB} \times 1024 = 204,800\text{ MB} \div 90\text{ days} \approx \mathbf{2,275\text{ MB per day}}$; $5\text{ h} \div 5\text{ days} = \mathbf{60\text{ min per day}}$
- Storage overflows at **A4** (2,470 MB); time overflows at **A8** (70 min)
- Final report: demand **9,165 MB and 110 min** against **2,275 MB and 60 min** — the activities must be ordered, reduced or deferred
- Written as a JavaScript **generator**: pause and resume at any line (Python version in the companion files)



Watch after class — Lesson 2.5.1



Capacity Planning — CompTIA Security+ SY0-701 — 3.4

Professor Messer · 3 min 53 s · YouTube

Why this video: How the supply of people, technology and infrastructure is matched to demand — the same balancing act as the resource envelope.

[Watch: https://www.youtube.com/watch?v=WGIT6-gNwqY](https://www.youtube.com/watch?v=WGIT6-gNwqY)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)

Videos are homework: under 15 minutes each, free, with transcripts. The lecture page carries the same links with their VirusTotal checks.



2.5.2

Criticality: rating what an asset is worth to the organization



Reading window 0:18–0:31

Concepts: asset · criticality · impact · high-water mark · data classification · RTO · single point of failure · exclusion

Asset and criticality — a statement about consequences

- An **asset** is anything of value that the network contains or supports: a device, a service, or a set of data
- **Criticality** = how much the organization would suffer if the asset **stopped doing its job**, or if its data were **disclosed or corrupted**
- It is about **consequences**, not about attackers
 - The file server's criticality does not change when a new vulnerability is published
 - It changes when the **business** changes — e.g. the workshop starts storing credit-card numbers
- Method borrowed from **FIPS 199** (Federal Information Processing Standards, NIST): simple, and it maps onto the **CIA** triad (Confidentiality, Integrity, Availability) of Topic 1

Asset	C	I	A	Criticality	Rule
FW-01	2	3	3	3	$\max(2, 3, 3) = 3$
SW-01	1	2	3	3	$\max(1, 2, 3) = 3$
SW-02	1	2	2	2	$\max(1, 2, 2) = 2$
AP-01	2	2	2	2	$\max(2, 2, 2) = 2$
SRV-FILE-01	3	3	3	3	$\max(3, 3, 3) = 3$
NAS-01	3	3	2	3	$\max(3, 3, 2) = 3$

Three impact questions, each answered from 1 to 3 (1/2)

Confidentiality impact — if the data were read by someone who should not read it?

1 limited: public or harmless information · 2 serious: internal information, embarrassment, some cost · 3 severe: personal information protected by law, trade secrets, passwords, financial data

Integrity impact — if the data or the configuration were modified without authorization?

1 limited: easy to notice and correct · 2 serious: wrong decisions or wrong products for a while · 3 severe: a safety risk, a financial loss, corrupted backups, physical damage



Three impact questions, each answered from 1 to 3 (2/2)

Availability impact — if the asset stopped working, what would happen, and how fast?

1 limited: an inconvenience; a workaround exists · 2 serious: a team stops for hours · 3 severe: the whole organization stops, or a legal or contractual deadline is missed

The high-water mark rule

The asset's criticality is the HIGHEST of the three numbers. One severe impact is enough to make the asset critical. NAS-01: availability only 2 (nobody uses it during the day), but a corrupted backup is discovered on the day it is needed — integrity 3 — so NAS-01 is critical (3).



Three helpers for the three answers

1

RTO (Recovery Time Objective) — the longest interruption the organization can tolerate before the damage becomes serious; a short RTO means a high availability impact

2

Single point of failure — a component whose failure stops everything that depends on it: FW-01 for Internet and hosted e-mail, SW-01 for the whole server room

3

Data classification — labelling data by sensitivity (public, internal, confidential, personal information). Any asset that stores or processes personal information gets confidentiality 3 — Law 25 imposes obligations and penalties, and the CAI (Commission d'accès à l'information du Québec) can investigate

Three rules that keep ratings consistent — and one exclusion

- Rate the impact **on the organization**, never the replacement price — a 400 \$ firewall can be the most critical asset in the building
- Rate assets with the **same data and role as a group** (the five office workstations) and say so in the register
- Write **one sentence of justification** per asset — a number without a reason cannot be defended when the owner asks
- An asset the owner **excluded** (the guest Wi-Fi) is **not rated**: it is recorded as an exclusion with the **reason and the date**
 - An auditor, or next year's technician, must see that the gap was a decision and not an oversight

Asset	C	I	A	Criticality	Rule
FW-01	2	3	3	3	$\max(2, 3, 3) = 3$
SW-01	1	2	3	3	$\max(1, 2, 3) = 3$
SW-02	1	2	2	2	$\max(1, 2, 2) = 2$
AP-01	2	2	2	2	$\max(2, 2, 2) = 2$
SRV-FILE-01	3	3	3	3	$\max(3, 3, 3) = 3$
NAS-01	3	3	2	3	$\max(3, 3, 2) = 3$
PC-ACCT-01	3	3	2	3	$\max(3, 3, 2) = 3$
CNC-PC-01	1	3	3	3	$\max(1, 3, 3) = 3$
PC-OFFICE-01...05	2	2	1	2	$\max(2, 2, 1) = 2$
PC-SHOP-01	1	1	1	1	$\max(1, 1, 1) = 1$
PRN-01	1	1	1	1	$\max(1, 1, 1) = 1$
MAIL-CLOUD	3	2	2	3	$\max(3, 2, 2) = 3$
GUEST-WIFI	excluded — recorded with reason and date, not rated				

7 critical • 3 serious • 2 limited • 1 exclusion — criticality alone cannot order the work.

Example 2.5.2 — same building, different consequences

SRV-FILE-01 → 3

Every customer drawing and quote — the owner calls them "the business". Read by a competitor: 3. A wrong dimension makes a wrong cabinet: 3. Stopped: nobody can work: 3.

PRN-01 → 1

Prints internal documents; a second printer exists in the office. Limited on all three questions.

NAS-01 → 3

Only the nightly backup job touches it: availability 2. But it is the last resort after ransomware or a disk failure, so an undetected corruption is severe: integrity 3 → critical.

Task: apply the three questions to every asset, derive each criticality with the high-water mark, write one sentence per asset. Deliverable: the asset criticality register (Table 2) — a required section of the Lab 1 plan; in Lab 3 it decides how severe a reported anomaly is.

Table 2 — the criticality register of Val-des-Pins

Asset	C	I	A	Criticality	Justification (one sentence)
FW-01	2	3	3	3	Single point of failure for Internet and e-mail; a modified rule set opens the network
SW-01	1	2	3	3	The whole server room depends on it; no confidential data of its own
SW-02	1	2	2	2	Shop floor loses its network for hours; machines keep running
AP-01	2	2	2	2	Staff Wi-Fi carries internal traffic; wired ports remain available
SRV-FILE-01	3	3	3	3	Drawings and quotes are confidential; a corrupted drawing = a wrong product; everyone works from it
NAS-01	3	3	2	3	A corrupted backup is discovered only on the day it is needed
PC-ACCT-01	3	3	2	3	Payroll and employee personal information (Law 25); altered payments are a direct loss
CNC-PC-01	1	3	3	3	A modified program can damage the machine; production stops when it stops
PC-OFFICE-01...05	2	2	1	2	Rated as a group; internal documents; a spare workstation exists
PC-SHOP-01	1	1	1	1	Time sheets and read-only drawings; nothing unique stored
PRN-01	1	1	1	1	A second printer is available
MAIL-CLOUD	3	2	2	3	Quotes and invoices; a forged message can misdirect a payment
GUEST-WIFI	—	—	—	excluded	Owner's decision (Class 6); recorded with reason and date, not rated

Simulator 2 — the criticality rater (high-water mark)

- Walks through the register, reads C, I, A, applies **max(C, I, A)**, prints the justification, colours one row of the heat map per step
- The excluded asset is handled as a **documented exclusion**, not a rating
- Final count: **7 critical (3), 3 serious (2), 2 limited (1), 1 exclusion**
- Pause on any asset and argue about the numbers before the next row appears
- Companion files: class7_sim2_criticality_rater.js, class7_fig2_criticality_heatmap.svg / .png

Asset	C	I	A	Criticality	Rule
FW-01	2	3	3	3	$\max(2, 3, 3) = 3$
SW-01	1	2	3	3	$\max(1, 2, 3) = 3$
SW-02	1	2	2	2	$\max(1, 2, 2) = 2$
AP-01	2	2	2	2	$\max(2, 2, 2) = 2$
SRV-FILE-01	3	3	3	3	$\max(3, 3, 3) = 3$
NAS-01	3	3	2	3	$\max(3, 3, 2) = 3$
PC-ACCT-01	3	3	2	3	$\max(3, 3, 2) = 3$
CNC-PC-01	1	3	3	3	$\max(1, 3, 3) = 3$
PC-OFFICE-01...05	2	2	1	2	$\max(2, 2, 1) = 2$
PC-SHOP-01	1	1	1	1	$\max(1, 1, 1) = 1$
PRN-01	1	1	1	1	$\max(1, 1, 1) = 1$
MAIL-CLOUD	3	2	2	3	$\max(3, 2, 2) = 3$
GUEST-WIFI	excluded — recorded with reason and date, not rated				

7 critical • 3 serious • 2 limited • 1 exclusion — criticality alone cannot order the work.

Watch after class — Lesson 2.5.2



Business Impact Analysis — SY0-701 — 5.2

Professor Messer · 2 min 55 s · YouTube

Why this video: Recovery time objective and recovery point objective in three minutes — the vocabulary behind the availability rating.

[Watch: https://www.youtube.com/watch?v=myl-v3mj7Kc](https://www.youtube.com/watch?v=myl-v3mj7Kc)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)



Data Types and Classifications — SY0-701 — 3.3

Professor Messer · 5 min 54 s · YouTube

Why this video: Regulated data, personal information and classification levels — the vocabulary behind the confidentiality rating.

[Watch: https://www.youtube.com/watch?v=ROW0_gZCVzk](https://www.youtube.com/watch?v=ROW0_gZCVzk)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)

Videos are homework: under 15 minutes each, free, with transcripts. The lecture page carries the same links with their VirusTotal checks.



2.5.3

Exposure: rating how likely trouble is



Reading window 0:31–0:44

Concepts: threat · vulnerability · exposure · likelihood · five exposure factors · CVE, NVD, CVSS · review date

Exposure — the likelihood side of risk

- Criticality answers "**how bad would it be?**"; exposure answers "**how likely is it?**"
- A **threat** is any potential cause of an unwanted incident: an attacker, a malicious program, a human error, a hardware failure
- A **vulnerability** is a weakness in the asset or in the way it is used
- **Exposure** = the degree to which a threat can reach the asset, combined with the degree to which it could succeed because of a vulnerability
- NIST SP 800-30 describes risk as a function of **likelihood** and **impact**: criticality gave the impact, exposure gives the likelihood
- A beginner cannot compute a probability for a small workshop — but can **observe five facts** per asset

Asset	E1	E2	E3	E4	E5	Score	Rating
FW-01	1	1	0	1	1		4 High (3)
SW-01	0	1	0	1	0		2 Moderate (2)
SW-02	0	1	1	0	0		2 Moderate (2)
AP-01	1	0	1	0	0		2 Moderate (2)
SRV-FILE-01	0	0	1	1	0		2 Moderate (2)
NAS-01	0	0	0	1	0		1 Low (1)
PC-ACCT-01	1	0	0	1	1		3 Moderate (2)
CNC-PC-01	0	1	1	0	1		3 Moderate (2)
PC-OFFICE-01...05	1	0	0	1	0		2 Moderate (2)
PC-SHOP-01	1	1	1	0	1		4 High (3)
PRN-01	0	1	1	0	0		2 Moderate (2)
MAIL-CLOUD	1	0	1	0	1		3 Moderate (2)

Highest: FW-01 (4) • lowest: NAS-01 (1) — exposure is independent of criticality.

The five exposure factors — each 0 (absent) or 1 (present) (1/2)

1

E1 — Internet contact: reachable from the Internet (open port, port-forwarding rule, remote-management service), or regularly receiving Internet content (e-mail attachments, downloads, browsing)

2

E2 — Known weakness: unsupported operating system or firmware, missing security updates, or a default or shared password

3

E3 — People and media: used by many people, through a shared account, from a place where anyone can plug in a cable, or with USB (Universal Serial Bus) sticks in daily use



The five exposure factors — each 0 (absent) or 1 (present) (2/2)

4

E4 — Privilege: holds or uses administrative credentials, keys or access rights that would let an attacker reach other assets — the set of assets reachable from a compromised one is its **blast radius**

5

E5 — History: an incident, a malware detection or suspicious activity involving the asset in the last 12 months

6

Score = the sum of the five factors, 0 to 5 → **rating:** 0–1 Low (1) · 2–3 Moderate (2) · 4–5 High (3) — the same 1–3 scale as criticality, so the two can be combined

Why these five factors — and two properties of exposure

- They match how small organizations are most often compromised, year after year, in **CCCS** threat assessments: phishing (E1), unpatched systems (E2), weak credentials and removable media (E3), abuse of administrative accounts (E4); a past incident predicts a future one (E5)
- **Exposure is independent of criticality**: PC-SHOP-01 holds nothing of value but scores 4; NAS-01 is critical but scores 1
- **Exposure changes**: a firmware update removes E2; an incident ages out of E5 after 12 months; a new remote-access rule adds E1 overnight
- So every exposure rating carries a **review date**, and the register is re-read whenever the network changes

Asset	E1	E2	E3	E4	E5	Score	Rating
FW-01	1	1	0	1	1		4 High (3)
SW-01	0	1	0	1	0		2 Moderate (2)
SW-02	0	1	1	0	0		2 Moderate (2)
AP-01	1	0	1	0	0		2 Moderate (2)
SRV-FILE-01	0	0	1	1	0		2 Moderate (2)
NAS-01	0	0	0	1	0		1 Low (1)
PC-ACCT-01	1	0	0	1	1		3 Moderate (2)
CNC-PC-01	0	1	1	0	1		3 Moderate (2)
PC-OFFICE-01...05	1	0	0	1	0		2 Moderate (2)
PC-SHOP-01	1	1	1	0	1		4 High (3)
PRN-01	0	1	1	0	0		2 Moderate (2)
MAIL-CLOUD	1	0	1	0	1		3 Moderate (2)

Highest: FW-01 (4) • lowest: NAS-01 (1) — exposure is independent of criticality.

Public information for factor E2 — observe, never scan

- **CVE** (Common Vulnerabilities and Exposures): the public catalogue of known vulnerabilities, each with a unique identifier
- **NVD** (National Vulnerability Database, NIST): the same entries with a **CVSS** (Common Vulnerability Scoring System) severity score from 0 to 10
- A device running a version with a known critical vulnerability gets **E2 = 1** without discussion
- Reading these lists is **observation**; **scanning** a network to discover versions is an **intrusive act** reserved for 420-3C1-DW and designated targets only
- In this course, versions come from documentation, the device's own screen, or the owner (Legal Notice, sections 6.3 and 7.6)

[CVE — cve.org](https://cve.org) · [NVD — nvd.nist.gov](https://nvd.nist.gov) · [Legal Notice v2.0](#)



Legal reminder — facts about people

- Factors E3 and E5 involve information about employees ("a phishing message was opened on PC-ACCT-01 in June")
- Keep it **factual, minimal and about the asset**
- **Never name the person** in the register, and never use the register to observe or profile an individual
- Monitoring a person — a colleague, a classmate, a relative — is **never a course activity** and may be a **criminal offence** (Legal Notice, sections 6.3 and 7.2)

[Open: Cyber.SoHo Legal Notice v2.0 — sections 6.3 and 7.2](#)



Table 3 — the exposure register of Val-des-Pins

Asset	E1	E2	E3	E4	E5	Score	Exposure	Observed facts (documents and interviews)
FW-01	1	1	0	1	1	4	3 High	Management port on the Internet; old firmware; admin credentials; login attempts last spring
SW-01	0	1	0	1	0	2	2 Mod.	Old firmware, default SNMP community name; password shared with FW-01
SW-02	0	1	1	0	0	2	2 Mod.	Old firmware; free ports on the shop floor
AP-01	1	0	1	0	0	2	2 Mod.	Signal reaches the parking lot; one passphrase for all staff
SRV-FILE-01	0	0	1	1	0	2	2 Mod.	22 users with mapped drives; holds the backup service account
NAS-01	0	0	0	1	0	1	1 Low	Reached only by the nightly backup job; one admin account; no incident
PC-ACCT-01	1	0	0	1	1	3	2 Mod.	Attachments and bank portal; payroll rights; phishing message opened in June
CNC-PC-01	0	1	1	0	1	3	2 Mod.	Unsupported system, no updates allowed; USB sticks; a virus found last winter
PC-OFFICE-01...05	1	0	0	1	0	2	2 Mod.	E-mail and browsing all day; local administrator rights
PC-SHOP-01	1	1	1	0	1	4	3 High	Browsing; unsupported system; shared account; adware last year
PRN-01	0	1	1	0	0	2	2 Mod.	Default administrator password; used by everyone
MAIL-CLOUD	1	0	1	0	1	3	2 Mod.	Reachable from anywhere; no MFA (multi-factor authentication); phishing wave in June

Simulator 3 — the exposure scorer

- Defines the thresholds **once**, reads each asset's five facts, **adds** them (nothing is weighted), converts to the 1–3 rating and draws a row: five cells, a score bar, the rating
- Last step names the two extremes: highest **FW-01** (4), lowest **NAS-01** (1) — both must be combined with criticality before any order is decided
- Companion files: class7_sim3_exposure_scorer.js, class7_fig3_exposure_matrix.svg / .png

Asset	E1	E2	E3	E4	E5	Score	Rating
FW-01	1	1	0	1	1		4 High (3)
SW-01	0	1	0	1	0		2 Moderate (2)
SW-02	0	1	1	0	0		2 Moderate (2)
AP-01	1	0	1	0	0		2 Moderate (2)
SRV-FILE-01	0	0	1	1	0		2 Moderate (2)
NAS-01	0	0	0	1	0		1 Low (1)
PC-ACCT-01	1	0	0	1	1		3 Moderate (2)
CNC-PC-01	0	1	1	0	1		3 Moderate (2)
PC-OFFICE-01...05	1	0	0	1	0		2 Moderate (2)
PC-SHOP-01	1	1	1	0	1		4 High (3)
PRN-01	0	1	1	0	0		2 Moderate (2)
MAIL-CLOUD	1	0	1	0	1		3 Moderate (2)

Highest: FW-01 (4) • lowest: NAS-01 (1) — exposure is independent of criticality.

Watch after class — Lesson 2.5.3



Analyzing Vulnerabilities — SY0-701 — 4.3

Professor Messer · 10 min 29 s · YouTube

Why this video: Vulnerability databases, the CVSS score, the exposure factor, and how the environment decides what to fix first — the reasoning behind factors E1 to E4.

[Watch: https://www.youtube.com/watch?v=eyVy1gKCuAU](https://www.youtube.com/watch?v=eyVy1gKCuAU)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)

Videos are homework: under 15 minutes each, free, with transcripts. The lecture page carries the same links with their VirusTotal checks.



2.5.4

From two ratings to an order — and to the monitoring plan

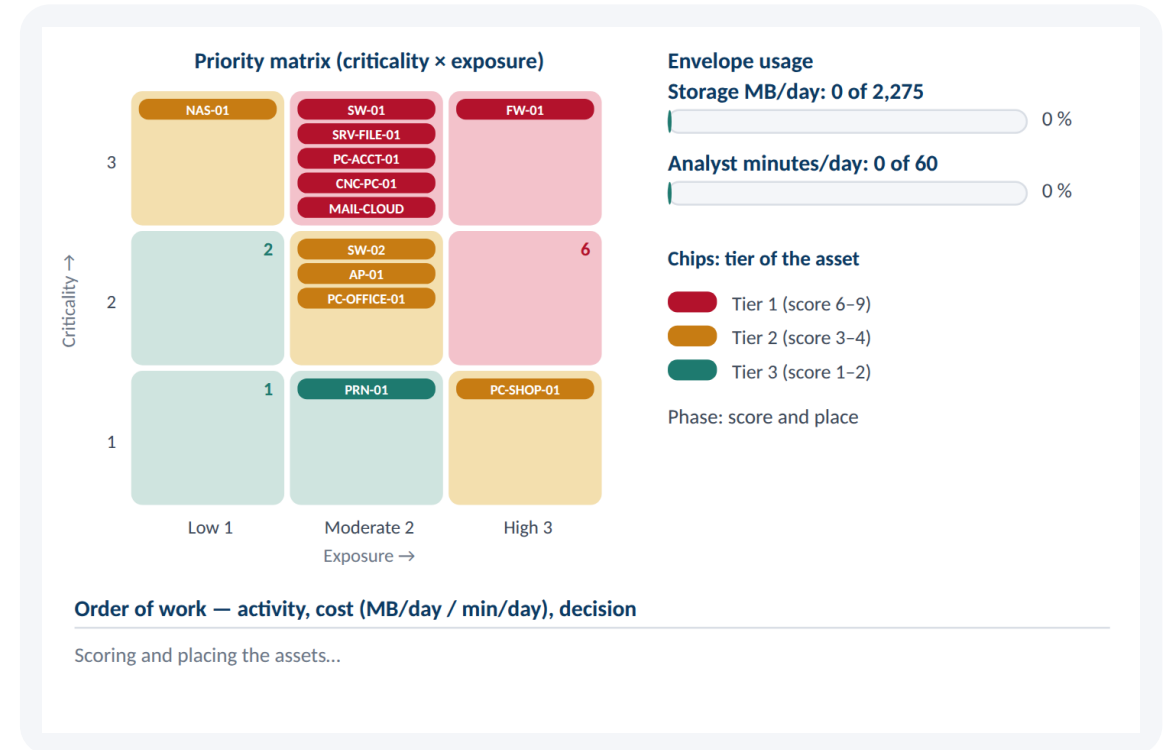


Reading window 0:44–0:55

Concepts: priority score · priority matrix · monitoring tier · tie-breaking · reduced activity · deferred activity · override · monitoring plan · review cycle

The priority score — multiply, do not add

- **Priority score = criticality × exposure**, from 1 to 9
- An asset needs **both** a serious consequence and a real likelihood to deserve continuous attention
 - Critical but unreachable: $3 \times 1 = 3$ (NAS-01)
 - Wide open but empty: $1 \times 3 = 3$ (PC-SHOP-01)
 - Critical and exposed: $3 \times 3 = 9$ (FW-01)
- With addition the three would score 4, 4 and 6 — the difference between "worth watching" and "watch first" would almost disappear



The priority matrix of Val-des-Pins

Three rows (criticality) by three columns (exposure), each cell coloured by its score: **6–9 High**, **3–4 Moderate**, **1–2 Low**. Risk management draws the same grid under the names risk matrix or heat map.

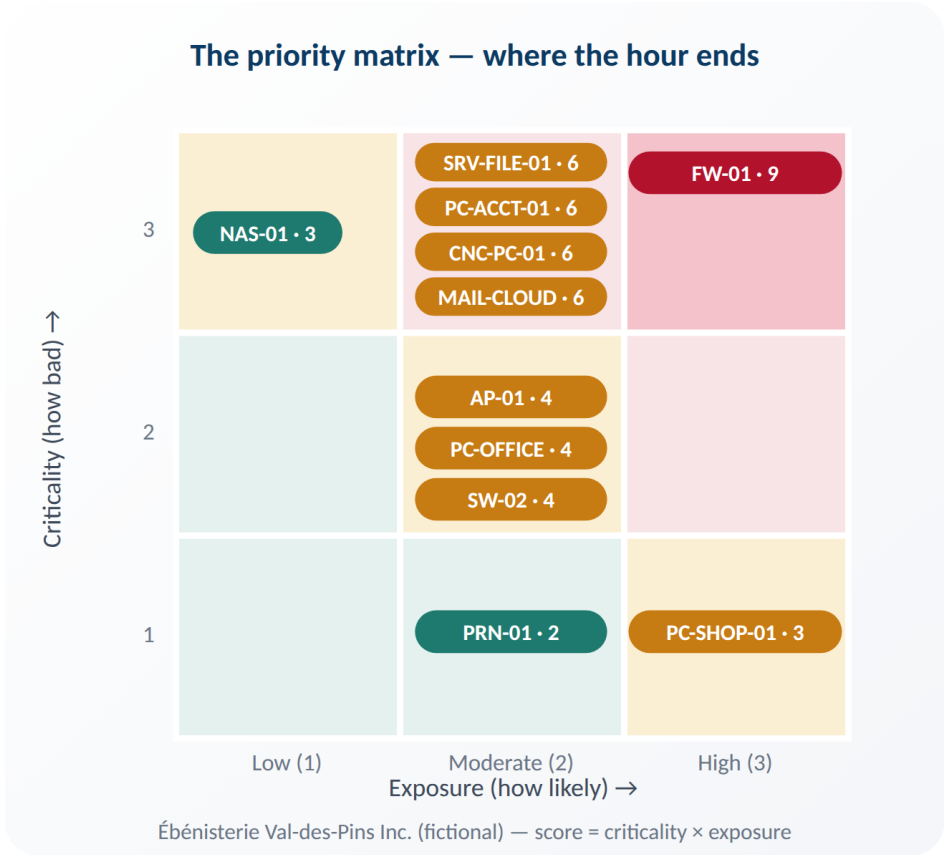


Table 4 — monitoring tiers: the score decides the effort

Tier	Score	Collection	Alerts	Review by the technician	Retention
Tier 1	6–9	Continuous (agent or syslog), started first in Lab 2	Automatic, immediate, on the predefined suspicious behaviours (Lesson 3.5)	Every working day	90 days
Tier 2	3–4	Continuous or a periodic export	Few; a weekly summary	Weekly	30 days
Tier 3	1–2	No dedicated collection	None	Included in the periodic baseline check (Lesson 3.4); re-rated when something changes	—

The tier says **how** an asset is watched; the order of work says **when**.



From tier to order — sorting and three tie-breaking rules

1

Sort the assets by **score, highest first**

2

Same score? The **higher criticality** comes first

3

Still tied? The **higher exposure** comes first

4

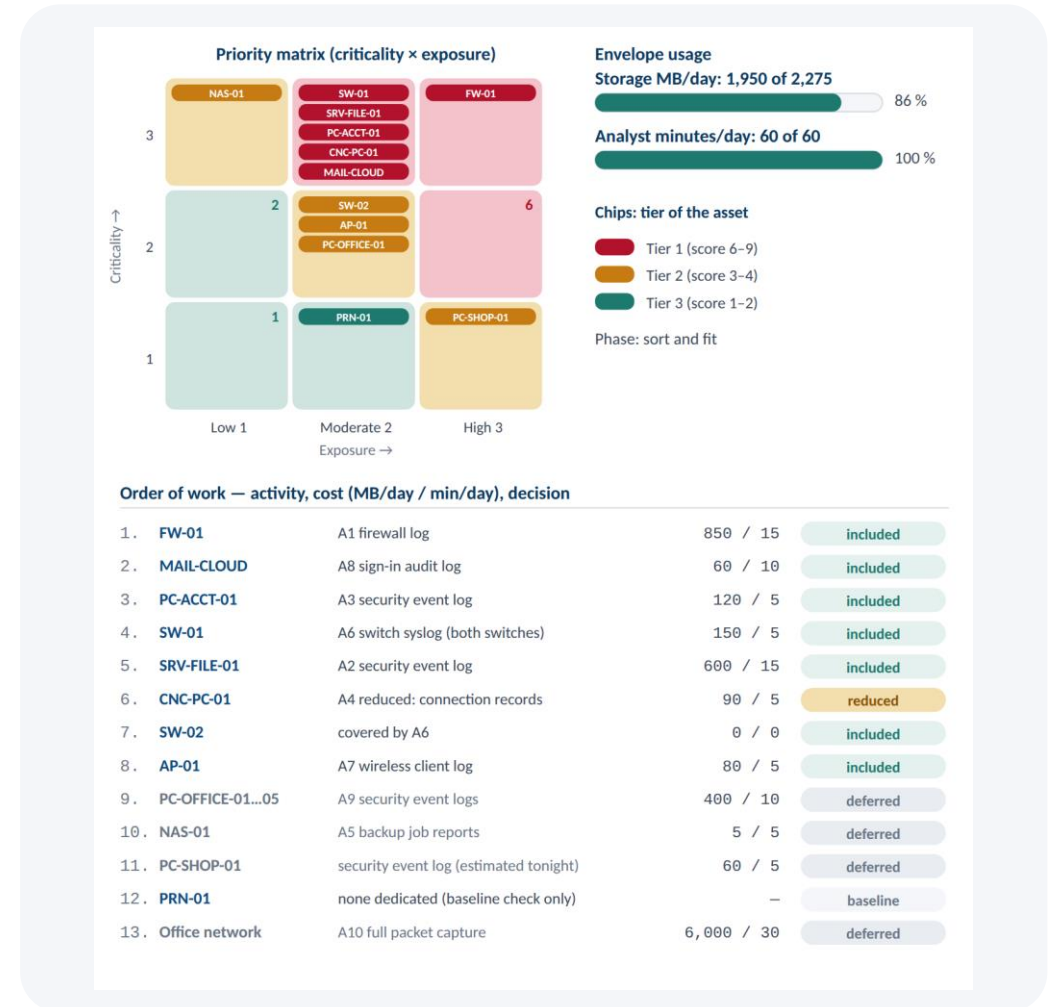
Still tied? The activity with the **lower daily cost** — a cheaper activity gives protection sooner for the same budget

Five assets tie at 6 with the same criticality and exposure: the cloud sign-in log (60 MB) goes first, then the accounting workstation, the switches, the file server, and CNC-PC-01 last.



Fitting the list into the envelope — reduce before you defer

- Walk down the sorted list; add each activity while **both** running totals — storage and analyst time — stay inside the envelope
- A Tier 1 activity that does not fit is **not dropped**: try a **reduced activity** first
 - Filtered logs instead of all logs; **connection records** (who spoke to whom, and when) instead of a full packet capture; sampling — the everyday work of Lesson 6.2
- Everything that still does not fit becomes a **deferred activity**: an accepted gap, written in the plan with its **reason and a review date**
- A gap that is written down is a decision; a gap that is not written down is a surprise



The override — a person still decides, in writing

- The computed order is a **proposal, not a verdict**
- An **override** is a documented change of the computed order, **with a reason**
- Two reasons are accepted without argument:
 - A **dependency** — the asset is the recovery path of other assets (NAS-01 for every Tier 1 asset)
 - A **legal obligation** — an asset holding personal information cannot be deferred without the owner's written decision
- Any other override must be explained in the plan and **signed off by the owner**

The monitoring plan — nine sections (1/2)

Section	Content	Lesson
1. Scope and network map	Name of the (fictional) organization; the topology diagram with every asset labelled; what is in scope and what is not	2.1, 2.2
2. Constraints	Organizational and operational constraints, each with its consequence for monitoring (no agent on CNC-PC-01; guest Wi-Fi excluded; provider logs only for MAIL-CLOUD)	2.3
3. Monitoring needs	What must be detected, on which asset, and how fast	2.4
4. Asset register	Asset, role, C, I, A, criticality, E1–E5, exposure, score, tier, justification, review date	2.5.2–2.5.4
5. Resource envelope	Storage per day and retention, analyst minutes per day, licences — agreed with the owner and dated	2.5.1

A plan is not a list of tools; it is the **written reasoning** that turns an inventory into an ordered set of activities.



The monitoring plan — nine sections (2/2)

Section	Content	Lesson
6. Ordered activities	Rank, asset, activity, data source, tool, cost (MB/day), cost (min/day), frequency of review, owner, tier, status (included / reduced / deferred)	2.5.4
7. Exclusions and deferred activities	Asset or activity, reason, decided by, date, review date	2.3, 2.5.4
8. Review cycle	Triggers (new asset, new Internet-facing service, incident) and the fixed schedule (quarterly for a small business)	2.5.4, 6.1, 6.3
9. Legal and privacy statement	All data is fictional; how captures and logs will be stored, minimized and deleted (Legal Notice, sections 6.7 and 7.2)	Legal Notice

The plan is **never finished**: a change in the network, an incident (E5 becomes 1), or the quarterly schedule triggers a review — the moment the reference database is updated (6.1) and deferred activities are reconsidered (6.3).



Example 2.5.4 — Table 6, the order of work (1/2)

Rank	Asset	Crit.	Exp.	Score	Tier	Activity	MB/day	min/day	Cumulative	Decision
1	FW-01	3	3	9	1	Firewall log (A1)	850	15	850 / 15	Included
2	MAIL-CLOUD	3	2	6	1	Sign-in audit log (A8)	60	10	910 / 25	Included
3	PC-ACCT-01	3	2	6	1	Security event log (A3)	120	5	1,030 / 30	Included
4	SW-01	3	2	6	1	Switch syslog, both switches (A6)	150	5	1,180 / 35	Included
5	SRV-FILE-01	3	2	6	1	Security event log (A2)	600	15	1,780 / 50	Included
6	CNC-PC-01	3	2	6	1	Full capture (A4) → connection records	900 → 90	10 → 5	1,870 / 55	Reduced (full capture exceeds storage)



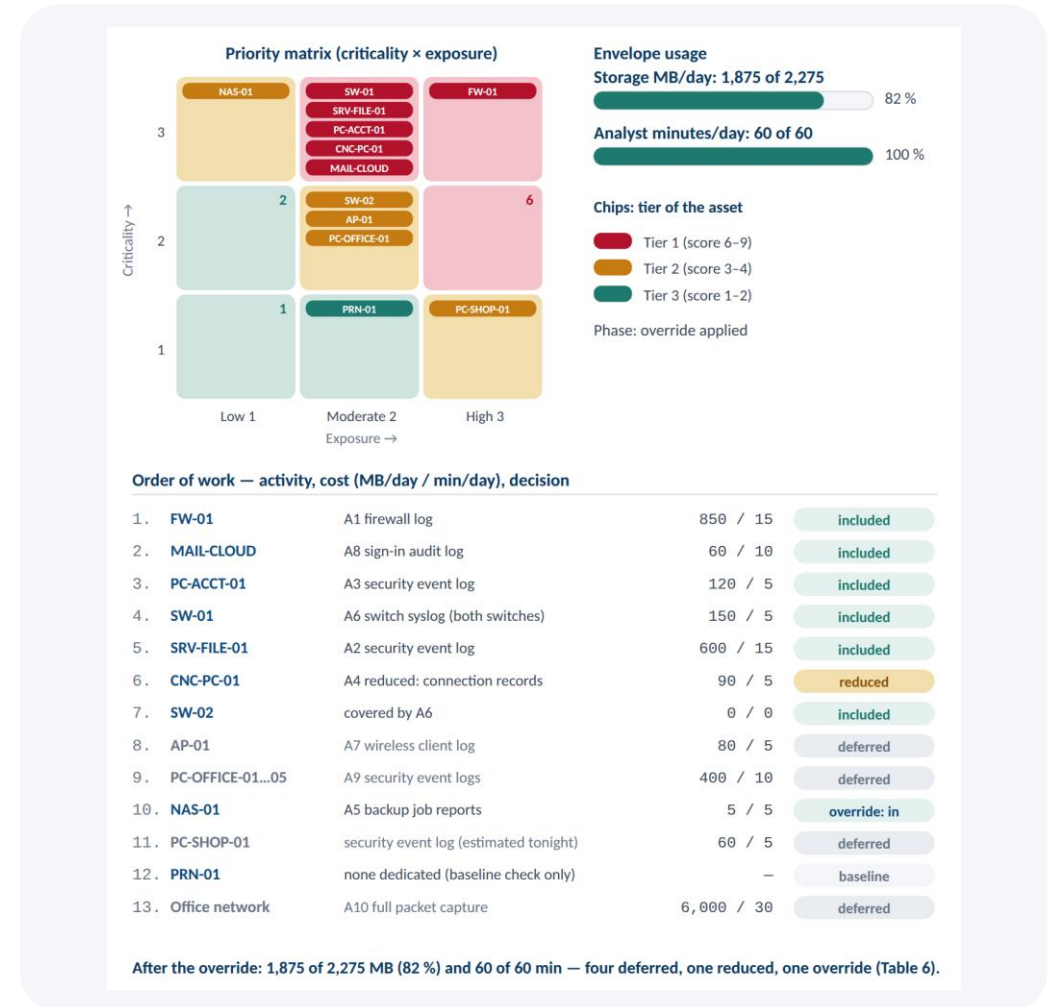
Example 2.5.4 — Table 6, the order of work (2/2)

Rank	Asset	Crit.	Exp.	Score	Tier	Activity	MB/day	min/day	Cumulative	Decision
7	SW-02	2	2	4	2	Covered by A6	0	0	1,870 / 55	Included
8	AP-01	2	2	4	2	Wireless client log (A7)	80	5	—	Deferred by override (swapped with NAS-01); review Oct 16
9	PC-OFFICE-01...05	2	2	4	2	Security event logs (A9)	400	10	—	Deferred (storage and time exceeded); review Oct 16
10	NAS-01	3	1	3	2	Backup job reports (A5)	5	5	1,875 / 60	Included by override — dependency: recovery path of every Tier 1 asset
11	PC-SHOP-01	1	3	3	2	Security event log (estimated tonight)	60	5	—	Deferred (time exceeded); review Oct 16
12	PRN-01	1	2	2	3	None dedicated	—	—	—	Baseline check only
Envelope used after the override							1,875 of 2,275 (82 %)	60 of 60	Four deferred (incl. A10), one reduced, one override	



Simulator 4 — the priority planner (score, tier, fit, override)

- **Score and place** each asset on the 3×3 matrix; **sort** with the three tie-breakers; **fit** while both totals stay inside the envelope; **reduce** a Tier 1 activity before **deferring** it; apply the documented **override**
- 27 steps; the final step prints the envelope usage (**1,875 of 2,275 MB, 60 of 60 min**) and the deferred list — this is Table 6
- Pause at the fitting steps to discuss why an activity is reduced or deferred, and at the last step to discuss why a person still decides
- Companion files: class7_sim4_priority_planner.js, class7_prioritize.py (all four steps in Python), class7_fig4_priority_matrix.svg / .png



Watch after class — Lesson 2.5.4



Risk Analysis — SY0-701 — 5.2

Professor Messer · 9 min 13 s · YouTube

Why this video: Qualitative risk assessment with a coloured grid, likelihood and impact, and the risk register — the general method behind the priority matrix.

[Watch: https://www.youtube.com/watch?v=Ykx7t54y-oo](https://www.youtube.com/watch?v=Ykx7t54y-oo)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)



Risk Management Strategies — SY0-701 — 5.2

Professor Messer · 3 min 12 s · YouTube

Why this video: Accepting a risk with a written exemption — its example is a machine whose vendor forbids updates, the exact situation of CNC-PC-01 — is what a deferred activity documents.

[Watch: https://www.youtube.com/watch?v=pmyuWY7Pbag](https://www.youtube.com/watch?v=pmyuWY7Pbag)

[Transcript on the author's site](#)

[Before you click \(Legal Notice, Annex C\): check youtube.com on VirusTotal](#)

Videos are homework: under 15 minutes each, free, with transcripts. The lecture page carries the same links with their VirusTotal checks.



Lab 1

Integrative Project, Part 1: map a small network and write its monitoring plan (5 %)

Reading window 0:55–1:00

Concepts: summary only — the complete laboratory guide, grading grid and submission form are provided separately



Lab 1 — the two deliverables, and how the project continues

Deliverable 1 — the network map

A topology diagram of the fictional workshop with every asset labelled with the naming key of Table 0: the two switches, the firewall, the access point, and the hosted e-mail service drawn outside the perimeter.

Deliverable 2 — the monitoring plan

A document with the nine sections of Table 5: scope, constraints, needs, the asset register (criticality, exposure, score, tier), the resource envelope, the ordered activities with their fit, exclusions and deferred activities with review dates, the review cycle, and the legal and privacy statement.

Worth 5 %; submitted online by the deadline in the lab guide (late policy: 10 % per day, nothing after seven days). Draws on Lessons 2.1–2.5 and your Class 6 inventory. Lab 2 (Oct 3) installs the monitoring tool on this network, Tier 1 first, in your order of work; Lab 3 (Oct 16) detects and reports an anomaly and proposes optimizations, starting from your deferred activities. Questions tonight through the class chat, afterwards by MIO (Messagerie interne Omnivox).



Three rules that apply to Lab 1 and to every lab of this course

- **Fictional only.** The organization, the assets, the people and the incidents are invented — never a real employer, a relative's business or any real network; never real personal information, real credentials or real screenshots (Legal Notice, sections 6.4, 6.7 and 18.2)
- **Authorized lab environment only.** Nothing in Lab 1 requires touching a network; a capture practised in advance for Lab 2 happens only inside your own isolated virtual lab — never on home, campus or workplace Wi-Fi (sections 6.1, 6.4 and 7.2; Annex D if the network belongs to someone else)
- **Signed acknowledgement.** One signed copy of Annex A of the Legal Notice is required before any laboratory access; the e-signature page will be provided separately

[Open: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0](#)



Links used in this lesson (1/2) — standards and references

- [NIST FIPS 199 — Security Categorization](#) — the 1–3 impact scale and the high-water mark rule (2.5.2) [\(VirusTotal check\)](#)
- [NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments](#) — risk as a function of likelihood and impact (2.5.4) [\(VirusTotal check\)](#)
- [NIST SP 800-92 — Guide to Computer Security Log Management](#) — log volumes and retention; background for the envelope (2.5.1) [\(VirusTotal check\)](#)
- [CCCS — Baseline Cyber Security Controls for Small and Medium Organizations](#) — Canadian guidance for organizations the size of Val-des-Pins [\(VirusTotal check\)](#)
- [Canadian Centre for Cyber Security \(CCCS\)](#) — the threat assessments behind the five exposure factors [\(VirusTotal check\)](#)
- [CIS Controls \(Center for Internet Security\)](#) — Control 1 (asset inventory) and Control 8 (audit log management) [\(VirusTotal check\)](#)
- [CVE — Common Vulnerabilities and Exposures](#) — the public catalogue of known vulnerabilities (factor E2) [\(VirusTotal check\)](#)
- [NVD — National Vulnerability Database](#) — the same entries with CVSS severity scores [\(VirusTotal check\)](#)



Links used in this lesson (2/2) — law, policy and safety

- [Cyber.SoHo — Legal Notice, Terms of Use and Acceptable Use Policy v2.0](#) — the terms governing this deck and all course materials [\(VirusTotal check\)](#)
- [Criminal Code of Canada \(R.S.C. 1985, c. C-46\)](#) — sections 342.1, 342.2, 430(1.1) and 184 [\(VirusTotal check\)](#)
- [Act respecting the protection of personal information in the private sector \(P-39.1\)](#) — the Québec law amended by Law 25 — why PC-ACCT-01 is confidentiality 3 [\(VirusTotal check\)](#)
- [Commission d'accès à l'information du Québec \(CAI\)](#) — the provincial privacy authority [\(VirusTotal check\)](#)
- [Office of the Privacy Commissioner of Canada](#) — the federal privacy authority (PIPEDA) [\(VirusTotal check\)](#)
- [Dawson College — ISEP \(Institutional Student Evaluation Policy\)](#) — the College policy on evaluation [\(VirusTotal check\)](#)
- [BAnQ — free account registration](#) — required for O'Reilly and LinkedIn Learning access [\(VirusTotal check\)](#)
- [VirusTotal — URL check](#) — submit any link before opening it; a clean result is never a guarantee [\(VirusTotal check\)](#)
- [Google Safe Browsing — site status](#) — a second opinion on a domain [\(VirusTotal check\)](#)



What to remember from Class 7

- Two inputs — **resources** and **security requirements** — produce one ordered, written list
- **Criticality** = highest of the three impacts (how bad); **exposure** = five observed facts (how likely)
- **Priority score** = criticality × exposure → tier → order → fit into the **envelope**; reduce before you defer; document every override
- The **monitoring plan** is the written reasoning — and Lab 1 asks for it tonight
- Next: Lab 1 now · Quiz 2 tomorrow (Sept 26) · Midterm review Sept 28 · Midterm Oct 1 (in class)



[Legal Notice v2.0 — click to open](#)